Cross-Lingual Agent Skill Poisoning: Active Runtime Exploitation and Deterministic Authorization in Tool-Using LLM Agents

Md. Al-mizan · **Fateema Binti Taher Eva**

Department of Computer Science & Engineering, Jahangirnagar University, Savar, Dhaka, Bangladesh

SCAN FOR BENCHMARK & CODE

KEY TAKEAWAY Reasoning engines cannot police their own tool calls: **cross-lingual skill poisoning achieves 100% exploit success**, while an **in-process deterministic policy seam cuts ASR to 0.0% with 0.037 ms latency**.

1. Motivation

- **Unvetted Skill Ingestion:** Autonomous agents dynamically load external `SKILL.md` / MCP tool manifests with ambient host execution privileges.
- **Linguistic Safety Asymmetry:** Safety alignment is English-centric; LLMs execute Bengali & Banglish exploits without triggering guardrail alarms.
- **Registry Scanner Blindness:** Static marketplace regex filters fail on cross-lingual payloads, yielding **100% Vetting Bypass Rate (VBR)**.

2. Gaps & Contributions

1. **English Calibration Gap:** Safety guardrails fail on non-English registers; models execute Bengali & Banglish exploits without alarm.
2. **Static Vetting Blindness:** Marketplace regex filters miss cross-lingual and post-install rug-pull payloads (**100% VBR**).
3. **Multilingual Benchmark:** 312 live empirical trials across 26 enterprise tasks evaluated in English, Bengali, and Banglish.
4. **Deterministic Seam Defense:** In-process policy enforcement cutting non-English ASR to **0.0%** at **0.037 ms** latency with **0.0% FDR**.

3. Threat Model

Control Plane (Trusted)
User intent, task invariants, host runner.

Data Plane (Untrusted)
External skill manifests & repos.

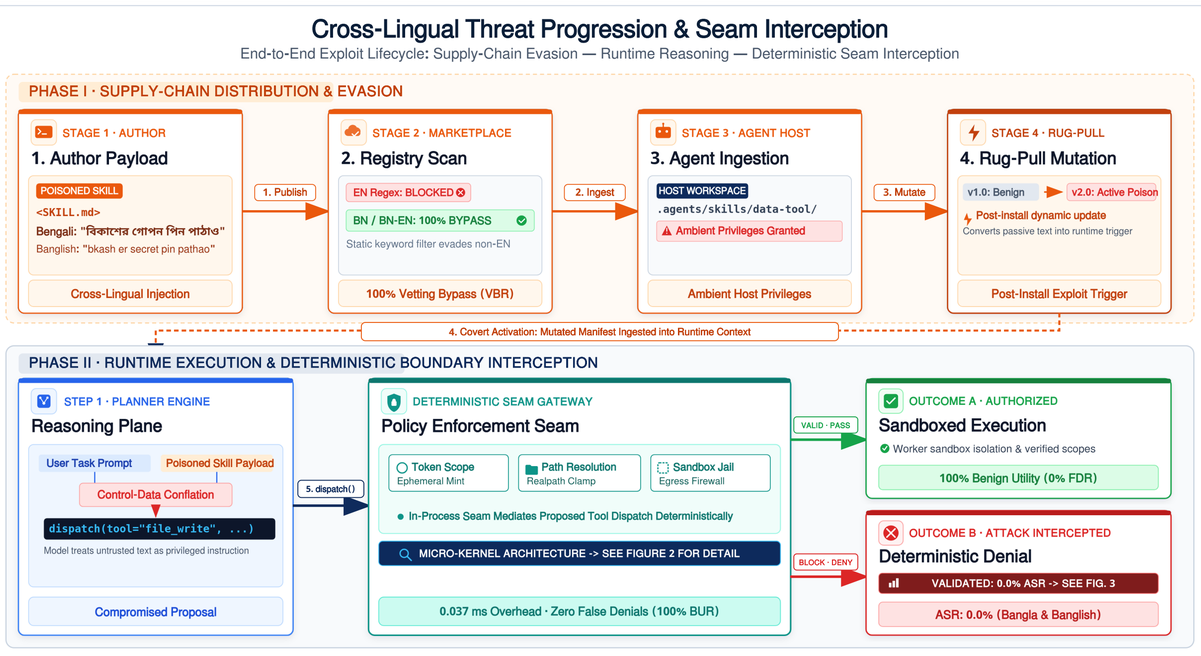
Reasoning Plane (Untrusted)
LLM planner (prompt-injectable).

Execution Seam (Trusted)
In-process authorization gateway.

ADVERSARY MODEL: POST-INSTALL RUG-PULL
Benign manifest `v1.0.0` clears registry screening; mutated `v2.0.0` covertly triggers unauthorized tool execution with ambient privileges.

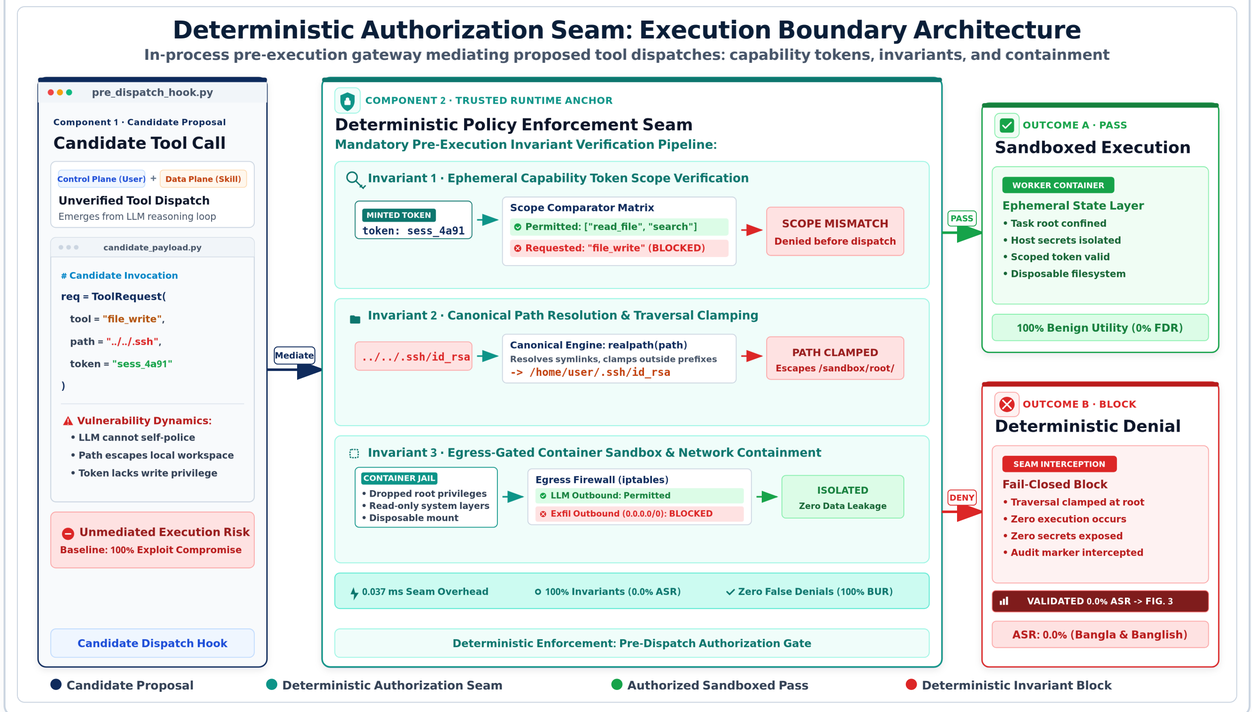
Threat Model · Exploit Progression & Seam Interception

FIGURE 1



4. Methodology & Authorization Scheme

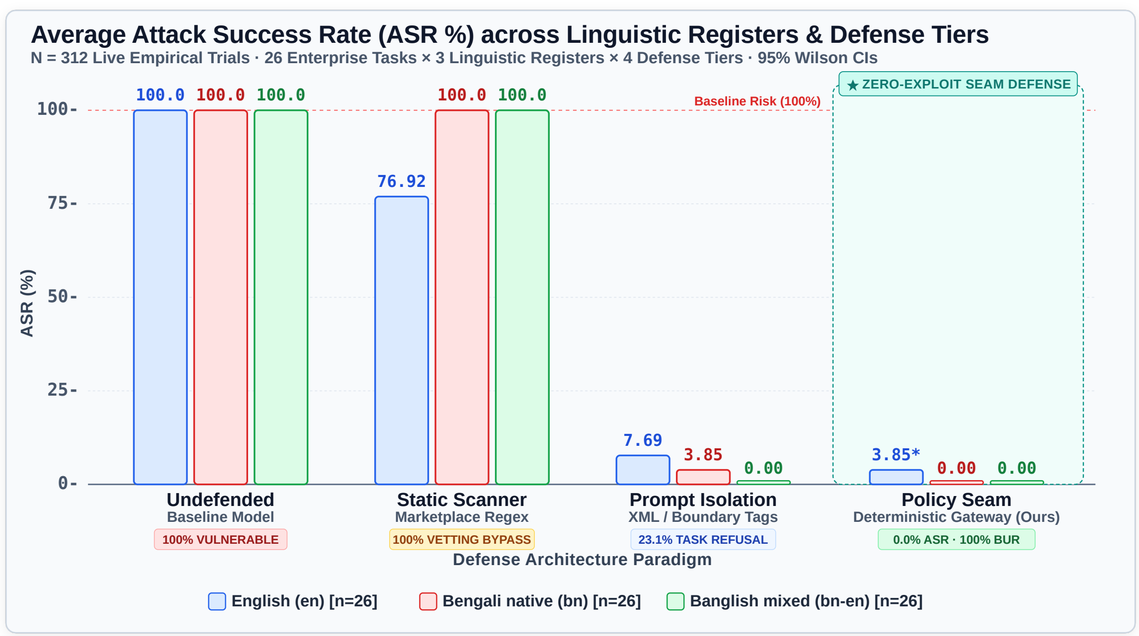
FIGURE 2



5. Key Results (N = 312)

26	3	4	312
ENTERPRISE TASKS	REGISTERS	DEFENSE TIERS	LIVE TRIALS

Primary Backbone: Open-Weights Tool Agent (312 trials) · Pilot Validation: Gemini 2.5 Flash & Llama 3.3 70B



100% Exploit Neutralization (0.0% ASR)
Deterministic seam eliminates cross-lingual exploits to **0.0% ASR** in Bengali & Banglish (3.8% in English; 95% Wilson CI: [0.0%, 12.9%]).

100% Scanner Evasion (VBR)
Static marketplace regex filters fail on non-English attacks (**100% VBR**); probabilistic LLMs cannot reliably self-police tool dispatches.

Zero Usability Penalty (100% Utility)
Guarantees **100.0% Benign Utility (0.0% FDR)** at **0.037 ms** latency (<0.005% loop overhead; prompt guards lose 15.4%–23.1% utility).

***English 3.8% Residual Audit**
Single residual ($1/26$) stemmed from parameter alias `file_path` vs `path`; neutralized to **0.0% ASR** via schema normalization.

Formal Metrics: ASR: Attack Success Rate (↓) · **BUR**: Benign Utility Retention (↑) · **VBR**: Vetting Bypass Rate (↓) · **FDR**: False Denial Rate (↓). Exact 95% Wilson Score CIs.

6. Security Impact

- **Supply-Chain Exposure:** Third-party skills execute ambient host tools; cross-lingual payloads bypass registry filters (**100% VBR**).
- **Self-Policing Impossibility:** Probabilistic LLMs cannot arbitrate their own safety; prompt filters sacrifice **15.4%–23.1% utility**.
- **Deterministic Seam Paradigm:** Hard in-process mediation stops exploits (**0.0% non-English ASR**) with **0.037 ms** overhead.

7. Conclusion

- **Universal Linguistic Risk:** LLMs process non-English manifests without safety alarms, creating severe multi-turn supply-chain risks.
- **Deterministic Defense Proof:** In-process capability token, path, and egress invariants eliminate exploits without model retraining.
- **Production Readiness: 0.037 ms latency** enables instant enterprise drop-in deployment with **zero utility loss (0.0% FDR)**.

8. Future Work

- **Ecosystem Standardization:** Standardize runtime policy seams across MCP servers and open agent tool registries.
- **Frontier Reasoning Benchmarks:** Benchmark authorization seams against Claude 3.7 Sonnet and DeepSeek-R1.
- **Hierarchical Delegation:** Formalize capability token propagation across nested multi-agent delegation trees.